Vulnerability Assessment Report

Target: Metasploitable2 (Lab Environment)
Tested by: Gayathri Ramesh
Date: 19/9/2026
Scope: Isolated home lab VM (192.168.56.101), tested via Kali Linux (192.168.56.102) on a host-only network — no external systems involved.

Executive Summary

This assessment tested an isolated home lab virtual machine (Metasploitable2) to identify security weaknesses using standard open-source tools. Testing identified five vulnerabilities, including three rated Critical, that would allow an attacker to gain full, unauthenticated root access to the system. The most severe issues include an exposed root shell requiring no credentials, a malicious backdoor embedded in an outdated FTP service, and a remote code execution flaw in the file-sharing service. Immediate remediation is recommended for all Critical findings, as each independently allows complete system compromise.

Summary of Findings

#	Finding	Severity
1	Metasploitable Bindshell — Unauthenticated Root Access	Critical
2	vsftpd Backdoor Command Execution (CVE-2011-2523)	Critical
3	Samba Remote Command Execution (CVE-2007-2447)	Critical
4	Anonymous SMB Access	Medium - High
5	Insecure Remote Execution Service (rexecd/rsh)	High

Methodology

A network scan was performed using nmap to identify open ports and running services on the target. Service versions were identified and cross-referenced against known vulnerability databases (CVE) and Exploit-DB using searchsploit. Manual verification was performed using smbclient to confirm findings.

Findings

Finding 1: Metasploitable Bindshell — Unauthenticated Root Access

Severity: Critical
Service/Version: bindshell (Metasploitable root shell) on port 1524
Description: A bind shell was found listening on port 1524. Unlike a normal service, this shell requires no username, password, or authentication of any kind. Simply connecting to port directly grants an interactive command shell with root (full administrator) privileges, with no barrier or trick required to access it.
Evidence: nmap -sV 192.168.56.101 identified the service as "bindshell — Metasploitable root shell" on port 1524 (Appendix A). Connecting directly using nc 192.168.56.101 1524 and running whoami confirmed

immediate root-level access with zero authentication (Appendix B).
Impact: Anyone with network access to this host can gain complete, unauthenticated control of the system in seconds, with no exploit code, credentials, or technical trickery required — making this the most immediately exploitable vulnerability identified in this assessment.
Recommendation: This service should not exist on any system. It should be immediately disabled and removed; there is no legitimate configuration in which an unauthenticated root shell is acceptable.

Finding 2: vsftpd Backdoor Command Execution (CVE-2011-2523)

Severity: Critical
Service/Version: vsftpd 2.3.4
Description: The target is running vsftpd version 2.3.4, which has a known security flaw where a malicious backdoor was inserted into the code by an unknown attacker. Connecting to FTP server with a username containing smiley emoji (:)) triggers the hidden backdoor. This gives direct access to TCP port 6200 with root access giving complete control of the server to an attacker.
Evidence: nmap -sV 192.168.56.101 confirmed the version as “vsftpd 2.3.4” (Appendix A). Additionally searchsploit vsftpd 2.3.4 confirmed a publicly known exploit exists for this exact version (Appendix C).
Impact: An attacker can gain full, unauthenticated root access to the system with no prior credentials or access required — making this another severe vulnerability found in this assessment.
Recommendation: Replace the compromised version with a secure, official release of vsftpd from your package manager or repository.

Finding 3: Samba Remote Command Execution (CVE-2007-2447)

Severity: Critical
Service/Version: Samba smbd 3.0.20 (Debian)
Description: The target is running Samba version 3.0.20, which contains a known vulnerability in the "username map script" feature. This flaw allows an attacker to execute arbitrary commands on the system remotely, without authentication.
Evidence: nmap --script smb-os-discovery 192.168.56.101 confirmed exact version as "Samba 3.0.20-Debian" (Appendix D).
Impact: An attacker could gain full remote control of the system.
Recommendation: Upgrade Samba to a patched version (3.0.25rc3 or later), or disable the vulnerable username map script feature if the upgrade isn't feasible.

Finding 4: Anonymous SMB Access

Severity: Medium
Service/Version: Samba smbd 3.0.20
Description: The Samba service allows anonymous (unauthenticated) login, granting access to shared folders including tmp, opt, and administrative shares without requiring credentials.
Evidence: smbclient -L 192.168.56.101 connected successfully with no password, listing accessible shares (Appendix E).
Impact: Any user on the network can browse shared files, potentially exposing sensitive data or providing a foothold for further attacks.
Recommendation: Disable anonymous/guest access to Samba shares; require authentication for all share access.

Finding 5: Insecure Remote Execution Service (rexecd/rsh)

Severity: High
Service/Version: netkit-rsh rexecd on port 512
Description: A remote command execution service, part of the old “r-commands” suite. It transmits usernames and passwords as plaintext over the network, no encryption at all. This enables the attacker to intercept credentials just by watching the network traffic — no cracking or exploiting needed.
Evidence: nmap -sV 192.168.56.101 identified the netkit-rsh rexecd service running on port 512 (Appendix A). The rexec protocol is documented to transmit authentication credentials in plaintext without encryption, a known weakness of legacy "r-commands" services, which is why they have been deprecated in favor of secure alternatives such as SSH.
Impact: Anyone with network access could passively capture login credentials just by observing traffic — no active attack needed, which is part of what makes it dangerous.
Recommendation: Replace with secure remote administration protocols such as SSH

Appendices

Appendix A: nmap -sV scan — Port and Service Enumeration

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-19 02:08 -0400
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-serv
rs: No such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify
alid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.025s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:40:A3:7B (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux
kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.65 seconds
```

Appendix B: netcat (nc) — Bindshell Root Access Confirmation

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.56.101 1524
root@metasploitable:/# whoami
root
root@metasploitable:/#
```

Appendix C: searchsploit — vsftpd 2.3.4 Exploit Match

```
┌──(kali㉿kali)-[~]
└─$ searchsploit vsftpd 2.3.4
------------------------------------------------------------------------------ ---------------------------------
 Exploit Title                                                                |  Path
------------------------------------------------------------------------------ ---------------------------------
vsftpd 2.3.4 - Backdoor Command Execution                                     | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                        | unix/remote/17491.rb
------------------------------------------------------------------------------ ---------------------------------
Shellcodes: No Results
```

Appendix D: nmap --script scan — Samba Version Confirmation (smb-os-discovery)

```
┌──(kali㉿kali)-[~]
└─$ nmap --script smb-os-discovery 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-19 02:32 -0400
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-serve
rs: No such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify v
alid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.021s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:40:A3:7B (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-09-19T01:55:22-04:00

Nmap done: 1 IP address (1 host up) scanned in 2.12 seconds
```

Appendix E: smbclient — Anonymous Access Confirmation

```
┌──(kali㉿kali)-[~]
└─$ smbclient -L 192.168.56.101
Password for [WORKGROUP\kali]:
Anonymous login successful

        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        tmp             Disk      oh noes!
        opt             Disk
        IPC$            IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
        ADMIN$          IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            METASPLOITABLE
```